

MÓDULO 4 • PLENARIA P3

Del diseño a la primera vertical desplegada

ARQUITECTURA • MODELO DE DATOS • CONTRATO DE API • SEGURIDAD

Martes 22 de septiembre • 19:00 – 20:30

Diplomado en Desarrollo Web y Aplicaciones Móviles • UAJMS

M.Sc. Ing. Isaac Lange Aguilar • Gestión 2026

Noventa minutos, seis momentos

1

Cómo se califica el módulo

Cuatro entregas, tres cuestionarios y la defensa técnica

5 min

2

Lo que dejó el E1

Fallas que se repiten y lo que sí funcionó en las tutorías T2

15 min

3

Arquitectura que se despliega

Diagrama, patrón, piezas en producción y modelo de datos

25 min

4

Contrato de API y seguridad

Rutas, familia de errores, roles y secretos

20 min

5

Corrección en vivo

Tres voluntarios: diagrama o contrato de API

15 min

6

Lo que hay que dejar listo

E2 del sábado 26 y lo que viene

10 min

ANUNCIO

La nota sale de entregas, cuestionarios y defensa

Cuatro entregas (E1-E4), tres cuestionarios (Q2-Q4) y la defensa técnica. Nada más se califica.

Las entregas y sus cuestionarios

LA ENTREGA Y SU CUESTIONARIO CIERRAN EL MISMO SÁBADO A LAS 23:59

E1

SÁBADO 19 SEP • 10 %

Perfil de proyecto

Capítulo 1, metodología, requisitos y repositorio inicializado

YA ENTREGADO

E2

SÁBADO 26 SEP • 15 %

Vertical funcional

Diseño técnico, frontend navegable, API con CRUD y primer despliegue público

+ CUESTIONARIO Q2 • 5 %

ESTA SEMANA

E3

SÁBADO 3 OCT • 15 %

Checkpoint técnico

Autenticación y roles, pruebas con evidencia, borrador de Capítulos 1 y 2

+ CUESTIONARIO Q3 • 5 %

E4

SÁBADO 10 OCT • 25 %

Documento y sistema final

Documento completo, despliegue verificado, manuales y anexos

+ CUESTIONARIO Q4 • 5 %

Entrega tardía: hasta 72 horas, con 10 puntos porcentuales menos por día.

Pasadas las 72 horas la entrega no se recibe. Los cuestionarios no admiten atraso: cierran junto con su entrega.

Cómo se compone la nota del módulo

100 PUNTOS • APROBACIÓN CON 70

Componente	Peso	Qué se evalúa
E1 • Perfil de proyecto	10 %	Capítulo 1, metodología, requisitos y repositorio (ya entregado)
E2 • Vertical funcional	15 %	Diseño técnico, frontend, API con CRUD y primer despliegue público
E3 • Checkpoint técnico	15 %	Autenticación y roles, pruebas con evidencia, Capítulos 1 y 2
E4 • Documento y sistema final	25 %	Documento completo, despliegue verificado, manuales y anexos
Cuestionarios Q2, Q3 y Q4	15 % (5 c/u)	Uno con cada entrega, en el aula virtual: lo que se ve en plenarias y tutorías
Defensa técnica • T5	20 %	Demostración en vivo del sistema desplegado y respuesta a las preguntas

Cuestionarios y defensa: cómo funcionan

CUESTIONARIOS • 15 %

Uno con cada entrega: Q2, Q3 y Q4

Q2 con el E2 (sábado 26), Q3 con el E3 (3 oct) y Q4 con el E4 (10 oct). Valen 5 % cada uno.

15 preguntas al azar de un banco, 30 minutos, dos intentos: vale el mejor. No admiten atraso.

Preguntan lo que se ve en las plenarias y en las tutorías, y lo que ya tienen que estar aplicando en su propio proyecto.

DEFENSA TÉCNICA • 20 %

T5 • del 12 al 15 de octubre

En la franja de su grupo: 7 minutos de demostración en vivo y 5 minutos de preguntas.

Se demuestra el sistema desplegado que se entregó en el E4, no una versión local.

Quien no puede ejecutar ni explicar su solución pierde el componente. La rúbrica se publica el martes 29, con P4.

Quien construye su proyecto semana a semana aprueba los cuestionarios y llega a la defensa sin sorpresas.

Lo que ya no existe y lo que sigue igual

YA NO HAY

Sin cápsulas, foros ni laboratorios

No se publican cápsulas.

No hay foros, laboratorios ni nota de participación.

El contenido técnico que necesitan para cada entrega se ve en las plenarias (hoy y el martes 29) y en la tutoría de su grupo. De ahí salen los cuestionarios.

SIGUE IGUAL

Tutoría semanal y calendario de entregas

Su tutoría de 60 minutos, en la franja de su grupo, cada semana.

Las fechas de E2, E3 y E4 no cambian.

El documento es uno solo y crece: lo que se observó en el E1 se corrige en el mismo archivo que entregan con el E2.

Menos actividades, el mismo producto: sistema desplegado + documento monográfico, defendidos en T5.

BLOQUE 1 • LECTURA CRÍTICA

Lo que dejó el E1

Lo que se vio en las tutorías T2, sin nombres: son patrones, no casos.

01

Seis fallas que se repitieron

CADA UNA CUESTA PUNTOS ENTEROS EN LA RÚBRICA

1

Puntos críticos sin dato

La tabla dice lo que se piensa medir, no lo que se midió. Un número por punto crítico: frecuencia, tiempo, cantidad de errores.

2

El alcance vuelve a crecer

Tres roles, 19 RF, 13 entidades, inventario que se había sacado en T1. Máximo dos roles, 8-15 RF, 4-8 entidades.

3

Capítulo 1 y Capítulo 2 hablan de sistemas distintos

El objetivo promete reportes y citas; los RF construyen otra cosa. El alcance se escribe igual en todo el documento.

4

Plantilla sin llenar

Contrato de API con [recurso], stack vacío, marcas [PENDIENTE], hoja "Verificación previa" y textos de instrucción.

5

Texto de asistente pegado

"Propongo 15 requisitos...", referencias que no son fuentes. Usar IA está permitido; entregar su borrador sin revisar, no.

6

Repositorio que no se abre

Enlace vacío o privado. Sin repositorio accesible se pierde el criterio completo. Pruébenlo en una ventana de incógnito.

Un RNF sin número y un RF con un solo criterio de aceptación siguen restando.

Cada RF lleva dos criterios (camino feliz y error) en formato Dado / Cuando / Entonces; cada RNF, una métrica verificable.

Lo que sí funcionó

HAY PERFILES QUE YA ESTÁN EN NIVEL DE DEFENSA

FUNCIONA

Flechas con nombre

Diagramas de arquitectura donde cada flecha dice protocolo y formato. Se entiende el sistema sin que el autor lo explique.

FUNCIONA

Recorte por escrito

Lo que salió del alcance quedó declarado como Won't have, con el mismo detalle que un requisito.

FUNCIONA

Una regla de negocio que da sentido

"No se entrega lo que no está cobrado." Una regla así ordena los RF, las pruebas y la defensa.

FUNCIONA

Datos reales del contexto

Puntos críticos con números de un registro real o de la responsable del negocio. El problema deja de ser una opinión.

La diferencia entre un buen perfil y uno flojo no es el tema: es la evidencia.

Cinco riesgos técnicos que aparecieron en T2

TODOS APARECEN RECIÉN AL DESPLEGAR: POR ESO SE DESPLIEGA ESTA SEMANA

Riesgo	Qué pasa	Qué hacer
Archivos en el disco del servidor	En plataformas con contenedores, el disco se borra en cada redesplicue: se pierden fotos y comprobantes	Almacenamiento externo de objetos (S3 compatible, Cloudinary, Supabase Storage, Firebase Storage)
Stack pesado para una persona	Tres bases de código (web, móvil, API) sin una sola funcionalidad escrita a cinco días del E2	Una plataforma por rol; lo demás pasa a Could o Won't
Servicios lentos de habilitar	Cuentas en la nube que tardan días en aprobarse; servidores de identidad que piden mucha memoria	Levantarlo hoy. Si no corre en 48 h, plan B documentado
Capa gratuita que se duerme o se pausa	La primera petición tarda o el proyecto queda pausado tras días sin uso	Revisar hoy las condiciones vigentes del plan; abrirlo antes de cada revisión
Rol que se regala	El autorregistro entrega un rol que puede editar contenido oficial	La cuenta nueva nace con el menor privilegio (lo vemos en el bloque 3)

BLOQUE 2 • FUNDAMENTO

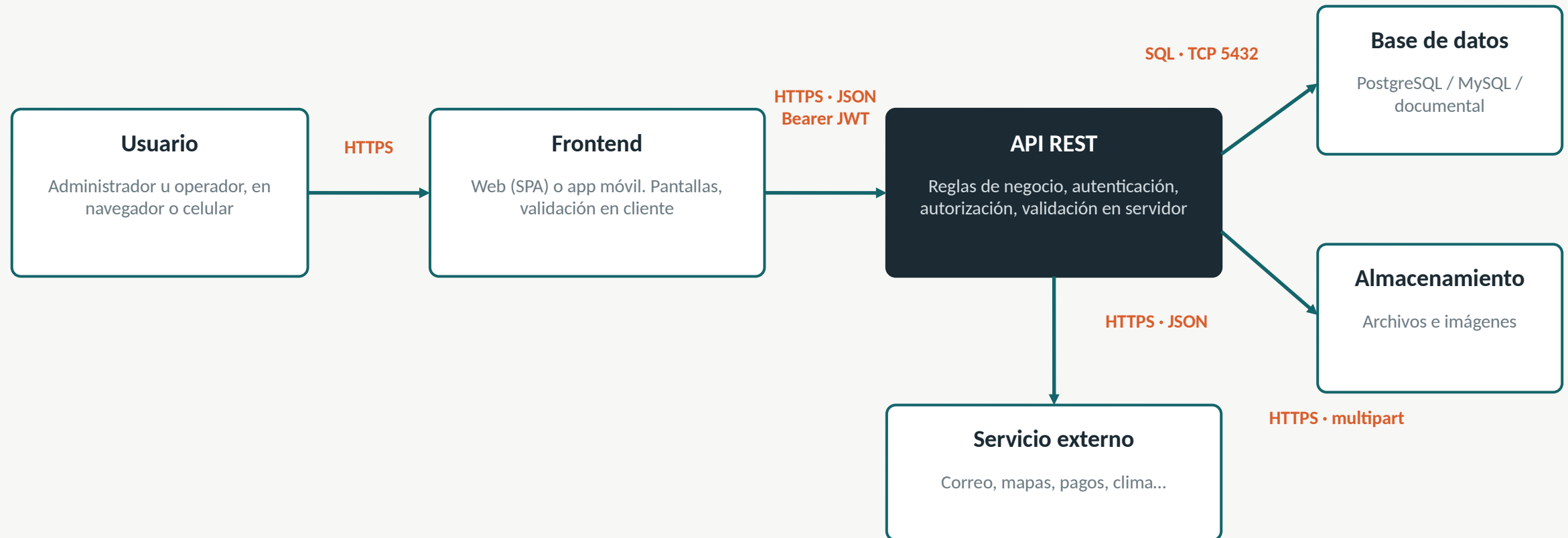
Arquitectura que se puede desplegar esta semana

Diagrama, patrón, piezas en producción y modelo de datos.

02

Arquitectura: cajas con responsabilidad, flechas con nombre

APARTADO 2.4.1 • -4 PUNTOS POR FLECHA SIN ETIQUETA



Si la flecha no dice cómo viaja el dato, el tribunal lo pregunta. Y es la pregunta más fácil de perder.

Hagan el diagrama en draw.io, Excalidraw o similar. Nada a mano, nada generado con decoración.

El patrón se elige contra los requisitos, no por moda

APARTADO 2.4.2 • CITEN LOS REQUISITOS POR SU ID

Patrón	Cuándo encaja en este diplomado	Cómo se justifica
Monolito modular (una API + un frontend)	Casi siempre. Un solo despliegue, un solo repositorio, una sola base	"Un único servicio cubre RF-01 a RF-12 y cumple RNF-01 (< 2 s) con la carga esperada"
Backend como servicio (Supabase, Firebase)	Cuando el CRUD domina y se quiere ahorrar el servidor propio	La seguridad pasa a reglas y políticas en la base (RLS): hay que documentarlas
Serverless (funciones)	Para una o dos tareas puntuales: un webhook, un envío programado	Complemento de uno de los anteriores, no arquitectura principal
Microservicios	No en tres semanas y una persona	Si ya existe, se declara como herencia y no se amplía

Regla del módulo: una persona, a lo sumo dos bases de código.

Si hay web y móvil, se reparten por rol: el administrador en la web, el operador en el celular. No se duplican pantallas.

Dónde vive cada pieza en producción

LA PLATAFORMA SE DECIDE HOY: EL SÁBADO SE ENTREGA UNA URL

Pieza	Dónde se despliega (ejemplos)	Trampa frecuente
Frontend web	Vercel, Netlify, Firebase Hosting, Cloudflare Pages	La URL de la API queda escrita a mano en el código: va en variable de entorno de build
App móvil	APK firmado o build de Expo/Flutter instalable	Apunta a localhost o a la IP de la casa: debe apuntar a la API pública
API	Render, Railway, Fly.io, una VM en la nube	La primera petición tarda si el servicio "duerme"; el puerto debe leerse de la variable PORT
Base de datos	Neon, Supabase, Railway, servicio gestionado del proveedor	Credenciales pegadas en el código; la base local no es la de producción
Archivos	S3 compatible, Cloudinary, Supabase Storage, Firebase Storage	Guardarlos en el disco del contenedor, que se borra al redespargar
Secretos	Variables de entorno del panel de la plataforma	Subir el .env al repositorio. Solo va .env.example, sin valores reales

Desplieguen el esqueleto antes que la funcionalidad

EL ORDEN DE TRABAJO QUE EVITA LA NOCHE DEL VIERNES



Si el esqueleto no está en línea el miércoles en la noche, no es un problema de código: es de infraestructura.

Llévenlo así a su tutoría o escriban antes. Un problema de despliegue detectado el miércoles se resuelve; el sábado, no.

Modelo de datos: cada dato vive en un solo lugar

APARTADO 2.4 • DE 4 A 8 ENTIDADES, CON CLAVES, RESTRICCIONES Y DICCIONARIO

ANTES

DESPUÉS

Seis tablas casi iguales

lugares, hoteles, restaurantes, actividades, gastronomía, eventos: seis CRUD, seis búsquedas



Una tabla recurso_turistico con un campo tipo y columnas opcionales: un CRUD, una búsqueda

Estado como texto libre

asistencia.estado VARCHAR: "presente", "Presente", "P"...



Dominio cerrado: CHECK (estado IN ('PRESENTE','AUSENTE','LICENCIA')) o enum

El mismo dato en dos lugares

El stock está en Producto y también en Inventario



Una fuente de verdad. Si el stock se calcula desde movimientos, no se guarda aparte

El precio que cambia

La venta apunta al precio actual del producto



La línea de venta guarda el precio del momento: es un dato histórico

Menos tablas bien restringidas valen más que muchas tablas con texto libre.

Del diccionario de datos al esquema

LO QUE EL DICCIONARIO PROMETE, LA BASE LO TIENE QUE HACER CUMPLIR

```
CREATE TABLE pedido (  
  id          BIGSERIAL PRIMARY KEY,  
  cliente_id  BIGINT NOT NULL REFERENCES cliente(id),  
  estado      VARCHAR(12) NOT NULL DEFAULT 'PENDIENTE'  
              CHECK (estado IN ('PENDIENTE','EN_COCINA',  
                                'LISTO','ENTREGADO')),  
  total       NUMERIC(10,2) NOT NULL CHECK (total >= 0),  
  observacion VARCHAR(200),  
  creado_en   TIMESTAMPTZ NOT NULL DEFAULT now()  
);  
CREATE INDEX idx_pedido_estado ON pedido(estado);
```

Campo	Tipo	Restricción	Descripción
id	BIGSERIAL	PK	Identificador
cliente_id	BIGINT	FK, no nulo	Quién hizo el pedido
estado	VARCHAR(12)	Dominio cerrado	Etapas del pedido
total	NUMERIC(10,2)	≥ 0	Monto en Bs
creado_en	TIMESTAMPTZ	No nulo	Fecha y hora UTC

Diccionario de datos en el documento: una tabla por entidad principal, no solo la primera.

Dinero en decimal, nunca en float. Fechas con zona horaria. Estados con dominio cerrado.

BLOQUE 3 • FUNDAMENTO

Contrato de API y seguridad

El contrato se escribe antes que el endpoint. La seguridad se hace cumplir en el servidor.

03

El contrato de la API es una tabla, y se escribe antes que el código

APARTADO 2.4.4 • MÉTODO, RUTA, AUTENTICACIÓN, PARÁMETROS Y RESPUESTAS

Método	Ruta	Auth / rol	Parámetros	Respuestas
POST	/api/v1/auth/login	Pública	correo, contraseña (body)	200 token · 400 · 401
GET	/api/v1/pedidos	Recepción, Cocina	?estado=&pagina=&limite=	200 lista · 400 · 401
POST	/api/v1/pedidos	Recepción	cliente_id, items[], observacion	201 creado · 400 · 401 · 403 · 422
GET	/api/v1/pedidos/{id}	Recepción, Cocina	id (ruta)	200 · 401 · 404
PATCH	/api/v1/pedidos/{id}/estado	Cocina	estado (body)	200 · 400 · 401 · 403 · 404 · 409
GET	/api/v1/salud	Pública	—	200 { "estado": "ok" }

Convenciones: /api/v1 • sustantivos en plural • filtros y paginación por query • fechas ISO 8601.

Documenten el contrato con OpenAPI (Swagger) o una colección de Postman exportada al repositorio.

La familia de errores también es parte del contrato

Código	Significa	Ejemplo en su sistema
400	La petición está mal formada	Falta un campo obligatorio o el tipo es incorrecto
401	No sé quién eres	Sin token, token vencido o inválido
403	Sé quién eres y no puedes	Recepción intenta cambiar el estado a "Listo"
404	No existe	Pedido con id inexistente
409	Choca con el estado actual	Entregar un pedido que ya fue entregado
422	Formato correcto, regla de negocio violada	Cantidad mayor al stock disponible
500	Falla nuestra	Nunca con el detalle interno ni la traza al cliente

```
HTTP/1.1 422 Unprocessable Entity

{
  "error": {
    "codigo": "STOCK_INSUFICIENTE",
    "mensaje": "Solo hay 3 unidades",
    "campos": {
      "items[0].cantidad": "máximo 3"
    }
  }
}
```

Un formato de error, el mismo en toda la API. El frontend lo muestra; no lo esconde.

Seguridad mínima que se revisa en la defensa

LINEAMIENTOS TÉCNICOS, PUNTO 4 • Y LO QUE EL TRIBUNAL PREGUNTA

01

Autenticación

JWT con expiración u OAuth.
Contraseñas con hash (bcrypt o argon2), nunca en texto plano

02

Autorización en el servidor

La API verifica el rol en cada ruta protegida. Ocultar el botón no es autorización

03

Menor privilegio

La cuenta nueva nace con el rol mínimo; los roles con poder los asigna el administrador

04

Validación doble

En cliente por usabilidad, en servidor por seguridad. El servidor nunca confía en el cliente

05

Secretos fuera del repositorio

Variables de entorno en la plataforma; .env en .gitignore; .env.example sin valores

06

HTTPS y CORS

Todo por HTTPS. CORS permite solo el dominio de su frontend, no ""

07

Errores sin detalles internos

Nada de trazas, consultas SQL ni versiones del servidor en la respuesta

08

Datos ficticios

Capturas y pruebas con datos inventados. Nunca teléfonos, nombres ni datos de salud reales

Si un requisito dice "solo el administrador", tiene que existir una prueba que muestre el 403.

El error de seguridad más caro: el rol que se regala

AUTORIZACIÓN EN EL SERVIDOR, RUTA POR RUTA

LO QUE PASÓ

Autorregistro con rol de editor

Cualquier persona crea una cuenta y recibe automáticamente permisos para crear, editar y desactivar la información oficial del sistema.

CORRECCIÓN

Cuentas creadas por el administrador

O la cuenta nace inactiva y sin permisos hasta que el administrador la habilite.

```
// Express · el orden importa
router.patch(
  '/api/v1/pedidos/:id/estado',
  autenticar,           // 401 si no hay token válido
  exigirRol('COCINA'),  // 403 si el rol no corresponde
  validar(esquemaEstado), // 400 si el cuerpo no cumple
  cambiarEstado        // recién aquí, la lógica
);
```

```
-- Supabase / PostgreSQL · lo mismo con RLS
CREATE POLICY cocina_actualiza ON pedido
  FOR UPDATE USING (rol_actual() = 'COCINA');
```

Con Supabase o Firebase, la clave pública del cliente es visible: la seguridad está en las políticas, no en la app.

La clave de servicio (service_role o credencial de administrador) nunca va en el frontend ni en el APK.

BLOQUE 4 • TALLER

Corrección en vivo

Tres voluntarios. Todos corrigen el suyo en paralelo.

04

Corrección en vivo · 15 minutos

TRES VOLUNTARIOS · COMPARTIMOS PANTALLA Y CORREGIMOS FRENTE A TODOS

1

Comparten su diagrama o su contrato de API

Tal como está en el documento. Sin pulirlo antes.

2

Lo corregimos pieza por pieza

Flechas sin etiqueta, rutas que faltan para un Must, errores no declarados, roles.

3

Ustedes corrigen el suyo en paralelo

Con la lista de la derecha, sobre su propio archivo.

MIENTRAS TANTO, REVISEN EL SUYO

- ¿Todas las flechas dicen protocolo y formato?
- ¿Cada Must tiene al menos una ruta?
- ¿Cada ruta dice quién puede llamarla?
- ¿Declara 401, 403 y 404, no solo 200?
- ¿Los estados tienen dominio cerrado?
- ¿Dónde se guardan los archivos?

Quien ofrece su diagrama se lleva la corrección hecha, antes del E2.

CIERRE

Lo que hay que dejar listo esta semana

E2, tutorías y lo que viene.

05

E2 · Vertical funcional desplegada

CIERRA EL SÁBADO 26 DE SEPTIEMBRE A LAS 23:59

Pieza del E2	Qué se entrega
Documento	Apartados 2.4, 2.5 y 2.6 en borrador, con lo observado en el E1 ya corregido en el mismo archivo
Frontend navegable	Pantallas principales con datos reales de la API, estados de carga, vacío y error
API	Al menos un CRUD completo sobre la entidad principal, con el contrato del documento
Primer despliegue público	URL accesible (o APK instalable), aunque sea incompleto. En la Tabla 1 y en el README
Repositorio	Commits en días distintos durante la semana; .env fuera del repositorio

Una vertical = login + un flujo Must, de la pantalla a la base y de vuelta, en producción.

Mejor un flujo completo en línea que diez pantallas en localhost.

Antes del sábado, esta lista



La URL abre en una ventana de incógnito

Desde otro dispositivo, sin su sesión



El repositorio abre en incógnito

Público o con acceso dado al docente



El login funciona en producción

Con un usuario de prueba declarado en el documento



El CRUD principal funciona en línea

Crear, listar, editar y dar de baja



No hay secretos en el repositorio

Ni .env, ni claves en el código, ni en el historial



El documento no tiene restos

Sin [PENDIENTE], sin textos de plantilla, sin hoja de verificación

Se entrega todo junto en la tarea "E2 · Vertical funcional" y se rinde el Cuestionario Q2: ambos hasta el sábado 26 a las 23:59.

La entrega admite hasta 72 horas de atraso, con 10 puntos porcentuales menos por día. El cuestionario no admite atraso.

Lo que viene

DOS SEMANAS DE CONSTRUCCIÓN, UNA PLENARIA MÁS Y LA DEFENSA

Cuándo	Qué	Para qué
Jueves 24 sep • 20:00 y 21:00	Tutoría T2 • Grupos 5 y 6	Revisión del E1 y validación de la arquitectura
Sábado 26 sep • 23:59	E2 • Vertical funcional + Cuestionario Q2	Primer despliegue público
28 sep – 1 oct	Tutoría T3 • en la franja de su grupo	Revisión de código y del despliegue en vivo, borrador de Capítulos 1 y 2
Martes 29 sep • 19:00	P4 • última clase teórica	Pruebas con evidencia, despliegue productivo, monitoreo, manuales y defensa
Sábado 3 oct • 23:59	E3 • Checkpoint técnico + Cuestionario Q3	Autenticación y roles, pruebas con evidencia, Capítulos 1 y 2
Sábado 10 oct • 23:59	E4 • Documento y sistema final + Cuestionario Q4	Documento completo, despliegue verificado, manuales y anexos
12 – 15 oct • en su franja	T5 • Defensa técnica evaluada	7 min de demostración del sistema desplegado + 5 min de preguntas

Nos vemos el martes 29, a las 19:00.

P4 · Pruebas con evidencia, despliegue productivo, manuales y defensa

Esta semana

Esqueleto en línea el miércoles, vertical completa el sábado.

E2 + Q2 · sábado 26, 23:59

Documento, frontend, API con CRUD, URL pública y el cuestionario Q2.

Primero en línea, después completo.